

Privacy & Data Protection Specification

Multi-Jurisdictional Compliance Framework

US United States
HIPAA

JP Japan
APPI 2022

DE Germany
GDPR / BDSG

SA Saudi Arabia
PDPL 2023

4

Jurisdictions
Covered

47

Critical Gaps
Remediated

27

Compliance
Categories

24

Month
Roadmap

Purpose & Scope

- Multi-jurisdictional regulatory compliance — HIPAA, GDPR, APPI, PDPL
- Privacy-by-Design architecture with Privacy-Enhancing Technologies (PETs)
- Consent management, data subject rights, and patient sovereignty
- Incident response, breach notification & business continuity
- Third-party risk management and vendor governance
- AI governance, audit, and continuous compliance monitoring

Critical Success Factors

- Executive sponsorship and adequate budget allocation
- Appointment of Data Protection Officers (EU/Germany & Japan)
- Engagement of multi-jurisdictional legal counsel
- Role-based privacy training for all staff
- Privacy integrated into Software Development Lifecycle (SDLC)
- Regular privacy audits and real-time compliance monitoring

MULTI-JURISDICTIONAL COMPLIANCE OVERVIEW

US United States

HIPAA

- Privacy Rule — NPP & minimum necessary
- Security Rule — Admin / Physical / Technical
- Breach: 60-day individual notification
- HHS notification concurrent (500+ individuals)
- Business Associate Agreements (BAAs) required
- HITECH Act enforcement alignment

JP Japan

APPI 2022

- Sensitive personal info — explicit opt-in
- Third-party transfers — PPC notification
- Data subject rights — access, correction, deletion
- Cross-border transfer safeguards required
- Annual breach notification to PPC
- Retention limits and purpose limitation

DE Germany / EU

GDPR & BDSG

- Art 9 — special category health data
- DPO appointment — mandatory
- DPIA required for high-risk processing
- 72-hour breach notification to supervisory authority
- Data subject rights — full suite (Arts 15-22)
- Standard Contractual Clauses for transfers

SA Saudi Arabia

PDPL 2023 & NCA ECC

- Health data — sensitive category
- Data localization — primary servers in KSA
- SDAIA regulatory oversight
- NCA Essential Cybersecurity Controls
- Cross-border transfer approval required
- 72-hour breach notification to SDAIA

DATA GOVERNANCE HIERARCHY & CLASSIFICATION

BOARD / EXECUTIVE

Strategic Oversight & Accountability

CHIEF PRIVACY OFFICER

Policy Ownership & Regulatory Liaison

DATA PROTECTION OFFICERS (DPOs)

EU/Germany · Japan — Mandatory Appointment

PRIVACY ENGINEERING TEAM

Technical Controls & Architecture

DEPARTMENT DATA STEWARDS

Operational Compliance & ROPA Maintenance

ALL STAFF

Role-Based Training & Data Handling

DATA CLASSIFICATION FRAMEWORK

LEVEL 4 — CRITICAL

Examples: Genetic data, psychiatric records, HIV/STI status, substance abuse records

Controls: E2EE + HSM key storage + MPC + dual approval + air-gapped backup

Retention

10 years post last activity

LEVEL 3 — RESTRICTED

Examples: PHI/health records, diagnoses, medications, test results, biometrics

Controls: E2EE + AES-256 + MFA + RBAC + blockchain audit log

Retention

7 years (10 years minors)

LEVEL 2 — INTERNAL

Examples: Appointment details, provider names, general demographics, insurance

Controls: TLS 1.3+ + RBAC + standard access controls + audit logging

Retention

5 years

LEVEL 1 — PUBLIC

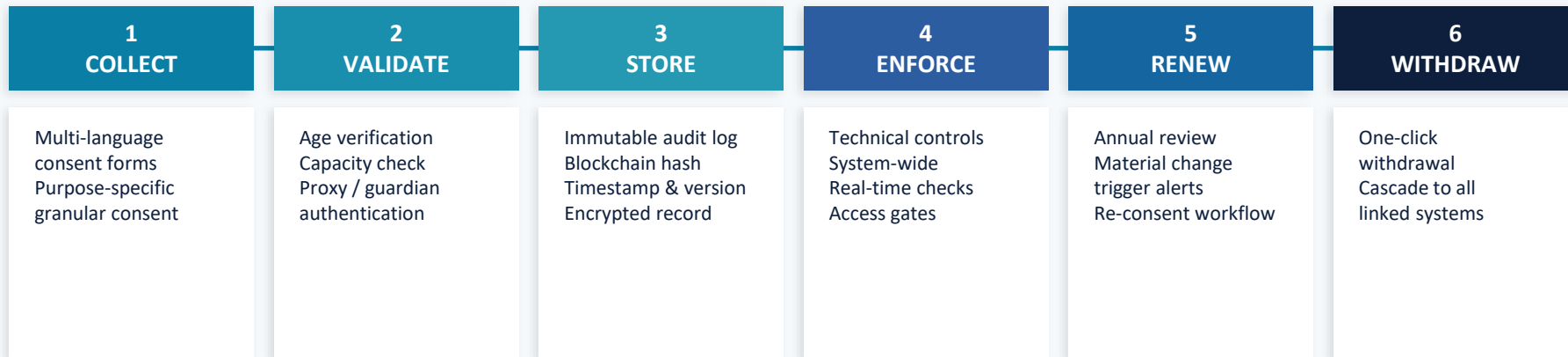
Examples: General health information, provider directories, public announcements

Controls: Standard access controls, integrity checks

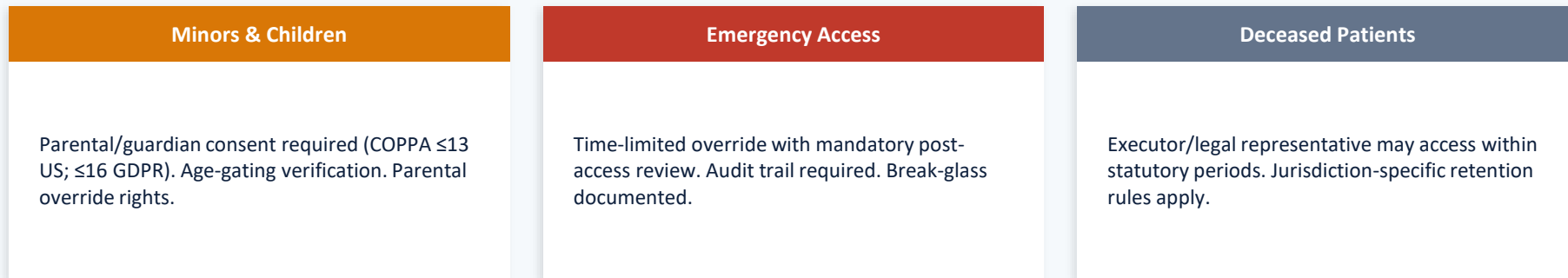
Retention

Indefinite

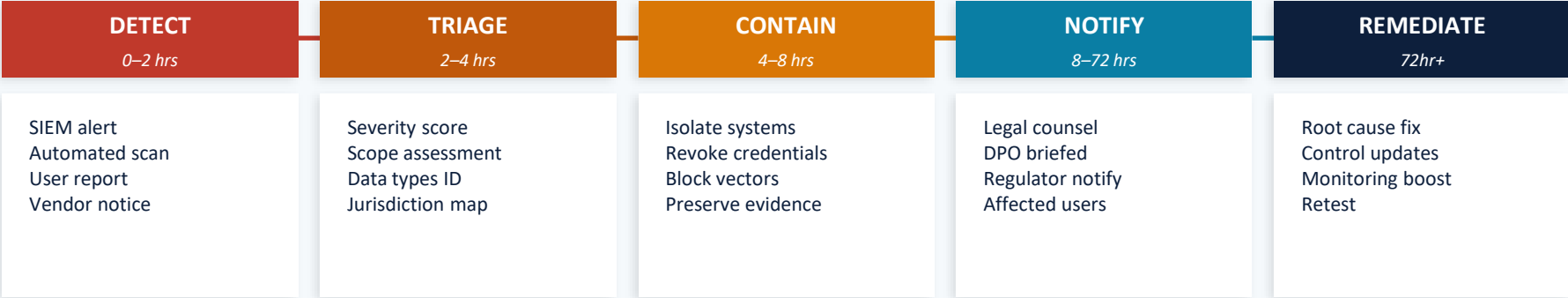
CONSENT MANAGEMENT LIFECYCLE



Special Consent Scenarios



INCIDENT RESPONSE & BREACH NOTIFICATION WORKFLOW



Multi-Jurisdictional Breach Notification Timelines

Jurisdiction	Regulator	Individual	HCO/Media	Legal Basis
us United States (HIPAA)	HHS — concurrent if 500+	Within 60 days	500+ in jurisdiction	HIPAA Breach Notification Rule
DE Germany (GDPR)	BSI / BfDI — 72 hours	Without undue delay	As required by DPA	GDPR Art 33 & 34
JP Japan (APPI)	PPC — promptly	As soon as practicable	N/A (case-by-case)	APPI 2022 Art 26
SA Saudi Arabia (PDPL)	SDAIA — 72 hours	Without undue delay	As directed by SDAIA	PDPL Art 20

PRIVACY-ENHANCING TECHNOLOGIES (PETs)

End-to-End Encryption

Spec: AES-256-GCM
+ TLS 1.3+

Use: All patient data
in transit & at rest

Homomorphic Encryption

Spec: CKKS / BFV
schemes

Use: Analytics on
encrypted data

Secure Multi-Party Computation

Spec: SMPC protocols
for providers

Use: Cross-provider
coordination

Differential Privacy

Spec: ϵ -differential
privacy ($\epsilon \leq 1$)

Use: Population-level
health analytics

Zero-Trust Architecture

Spec: NIST SP 800-207
alignment

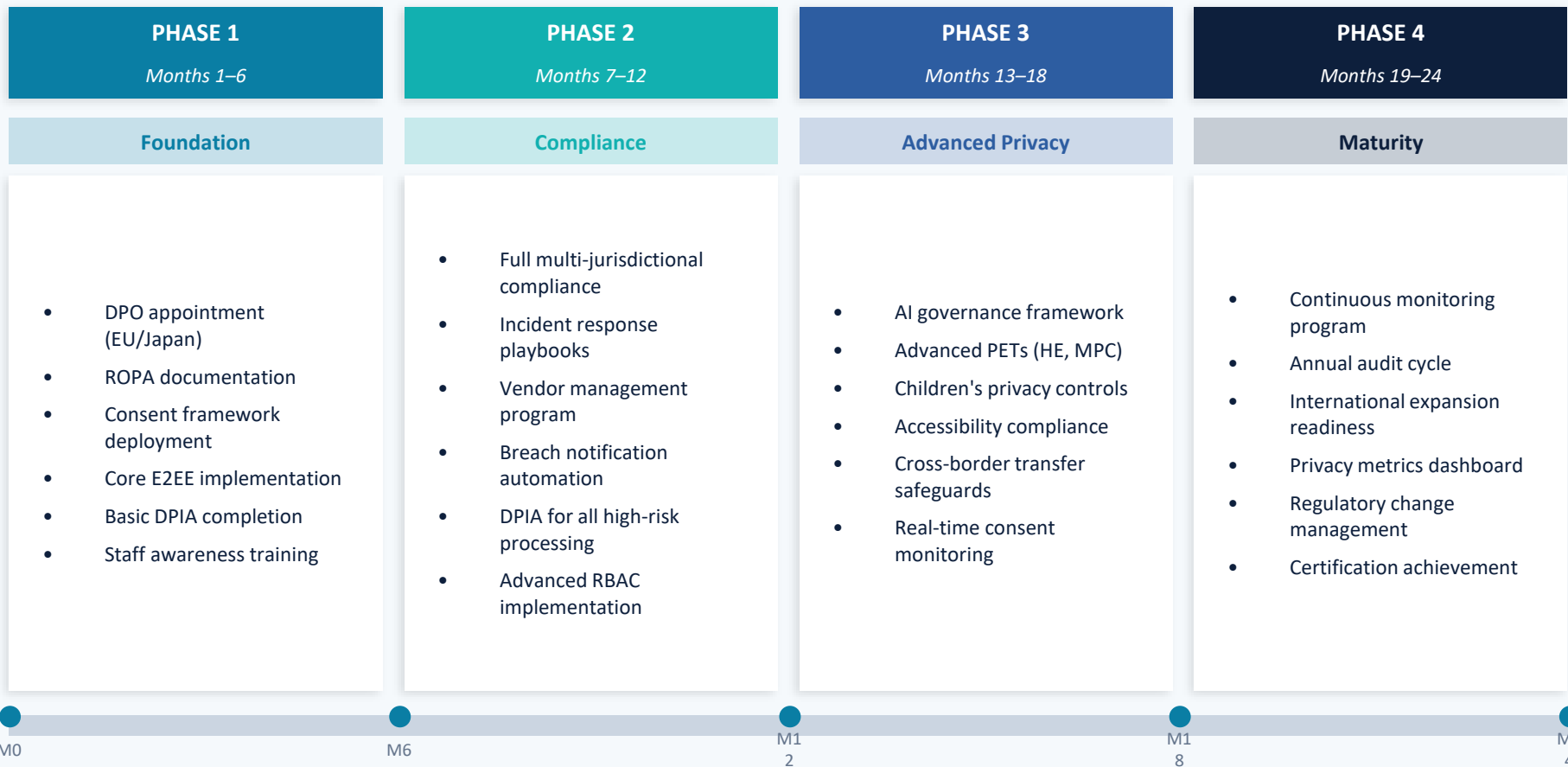
Use: Network &
access control

Blockchain Audit Logs

Spec: Immutable hash
chain records

Use: HIPAA accounting
& transparency

IMPLEMENTATION ROADMAP — 24 MONTHS



KEY PRIVACY METRICS & REPORTING STANDARDS

Consent Withdrawal Response Time ≤ 24 hrs Target	DSAR Fulfilment Rate 100% in 30 days Target	Data Breach Detection Time < 2 hours Target	Privacy Training Completion 100% Annually Target	Vendor Privacy Assessment Rate 100% Pre-engagement Target
---	--	---	---	--

Reporting Cadence & Standards

Real-Time	Weekly	Monthly	Quarterly	Annual
- SIEM alerts - Consent violations - Unauthorized access - Breach indicators	- Access anomalies - DSAR queue status - Consent withdrawal - Training completion	- KPI dashboard - Vendor assessments - Incident summary - Control effectiveness	- Board privacy report - DPIA review - Regulatory update - Audit findings	- Full compliance audit - ROPA refresh - DPO annual report - Roadmap review

THIRD-PARTY RISK & VENDOR GOVERNANCE

TIER 1 — CRITICAL	Examples: Cloud infra, EHR systems, payment processors Requirements: Full DPIA · SOC2 Type II · Annual audit · BAA / DPA	Review Cycle Quarterly
TIER 2 — HIGH RISK	Examples: Analytics platforms, AI/ML vendors, identity providers Requirements: Abbreviated DPIA · SOC2 Type I · Semi-annual review	Review Cycle Semi-annual
TIER 3 — STANDARD	Examples: Communication tools, general SaaS, professional services Requirements: Privacy questionnaire · Annual review · Standard DPA	Review Cycle Annual

Vendor Onboarding Due Diligence Flow



NEXT STEPS & IMMEDIATE ACTIONS

Required actions for executive approval and Phase 1 launch

01	Approve this specification and authorize Phase 1 budget	Board / CFO	March 1, 2026
02	Appoint DPOs for EU/Germany and Japan	CPO / Legal	March 15, 2026
03	Engage multi-jurisdictional legal counsel	General Counsel	March 15, 2026
04	Launch mandatory privacy awareness training for all staff	HR / Privacy Team	April 1, 2026
05	Complete ROPA documentation across all business units	Privacy Engineering	April 30, 2026
06	Deploy consent management framework across all jurisdictions	Engineering / CPO	May 31, 2026